

WHITE PLAINS HOSPITAL | CYBERSECURITY RISK REGISTER | Version 1.0 | April 2026

● CRITICAL (Score 20-25)				● HIGH (Score 12-19)		● MEDIUM (Score 6-11)		● LOW (Score 1-5)		Likelihood × Impact = Risk Score Scale: 1 (Very Low) to 5 (Very High)							
Risk ID	Risk Description	Risk Category	Affected Area	Likelihood (1-5)	Impact (1-5)	Risk Score	Risk Level	NIST CSF Function	Current Controls in Place	Treatment Strategy	Risk Owner	Target Date	Status	Residual Likelihood	Residual Impact	Residual Risk Score	Residual Risk Level
WPH-R01	Staff fall for phishing email giving attacker unauthorized access to Epic EHR system	Cybersecurity	All Departments / EHR	4	5	20	● CRITICAL	Protect / Detect	Basic email spam filter in place. Annual HIPAA training mentions phishing briefly.	REDUCE — Improve mandatory phishing simulation training quarterly. Deploy advanced email filtering. Enable MFA on all EHR	IT Security Manager	June 2026	Open — In Progress	2	4	8	● MEDIUM
WPH-R02	Employee shares login credentials with colleague, enabling unauthorized patient record access	Access Control	Clinical Staff / EHR	4	4	16	● HIGH	Protect	Password policy exists but is not technically enforced. No monitoring of shared logins.	REDUCE — Enforce unique credentials technically. Implement MFA. Add access monitoring and quarterly user access reviews.	Privacy Officer	May 2026	Open — High Priority	2	3	6	● MEDIUM
WPH-R03	Ransomware attack encrypts all hospital systems causing complete clinical operations shutdown	Malware / Ransomware	Entire Hospital	3	5	15	● HIGH	Protect / Detect / Recover	Basic antivirus on workstations. No tested backup and recovery plan. No network segmentation.	REDUCE — Implement network segmentation. Deploy EDR solution. Establish and test offsite backups. Purchase recovery services.	IT Manager	July 2026	Open — Critical	2	3	6	● MEDIUM
WPH-R04	Hospital employee accesses patient records without clinical justification — insider threat	Insider Threat	EHR / Patient Data	4	4	16	● HIGH	Detect / Protect	EHR has audit log capability but logs are not reviewed regularly. No formal access review process.	REDUCE — Implement monthly audit log reviews. Conduct quarterly user access reviews. Establish formal process for investigating suspicious activity.	Privacy Officer	June 2026	Open — In Progress	2	3	6	● MEDIUM
WPH-R05	Unpatched vulnerability in medical device connected to hospital network exploited by attacker	Medical Device Security	Clinical Equipment / Network	3	4	12	● HIGH	Identify / Protect	No formal medical device inventory. Patching is done ad hoc with no defined schedule.	REDUCE — Create complete medical device inventory. Establish monthly patching schedule. Implement network segmentation to isolate device.	IT Manager / Biomedical Engineering	August 2026	Open	2	3	6	● MEDIUM
WPH-R06	Third-party billing vendor stores patient PHI without a signed Business Associate Agreement	Vendor Risk	Billing / Patient Data	2	5	10	● MEDIUM	Identify / Protect	Vendor contracts exist but have not been reviewed for BAA compliance. No vendor risk program in place.	REDUCE — Conduct immediate vendor contract audit. Obtain signed BAAs from all vendors handling PHI. Establish formal vendor risk program.	GRC Analyst / Legal	May 2026	Open — Urgent	1	4	4	● LOW
WPH-R07	Primary server room flood or fire destroys patient data with no tested offsite backup available	Business Continuity	Server Room / All Data	2	5	10	● MEDIUM	Recover	Single on-premises server. No tested offsite or cloud backup. No disaster recovery plan documented.	REDUCE — Implement automated daily cloud backup. Document and test disaster recovery procedures quarterly. Define RTO and RPO targets.	IT Manager	July 2026	Open	1	3	3	● LOW
WPH-R08	Former employee account remains active after termination, enabling unauthorized system access	Access Control	All Systems	3	4	12	● HIGH	Protect	No formal offboarding procedure that includes IT account deactivation. HR and IT processes are not integrated.	REDUCE — Create formal IT offboarding checklist tied to HR termination process. Conduct monthly audit of active accounts against current employee roster.	HR Manager / IT Manager	May 2026	Open — High Priority	1	3	3	● LOW
WPH-R09	Patient health information transmitted between departments without encryption	Data Protection	Clinical Communications	2	4	8	● MEDIUM	Protect	Some email communications use standard unencrypted email. No policy requiring encrypted transmission of PHI.	REDUCE — Implement encrypted email solution for PHI transmission. Update data transmission policy to require encryption. Train staff on secure communication protocols.	IT Manager / Privacy Officer	July 2026	Open	1	3	3	● LOW
WPH-R10	Staff have not completed annual HIPAA security awareness training — compliance gap	Compliance / Training	All Staff	3	3	9	● MEDIUM	Protect	Training is required annually but completion is not tracked systematically. No consequences for non-completion.	REDUCE — Implement LMS-based training tracking. Set 100% completion target with management escalation for non-compliance. Report to leadership.	HR Manager / GRC Analyst	June 2026	Open — In Progress	2	2	4	● LOW
WPH-R11	No formal incident response plan exists — staff do not know what to do during a cyber incident	Incident Response	Entire Organization	2	5	10	● MEDIUM	Respond / Recover	No documented incident response plan. IT handles incidents informally with no defined escalation path.	REDUCE — Develop formal Incident Response Plan aligned to NIST CSF. Define roles and responsibilities. Conduct tabletop exercise within 90 days.	GRC Analyst / CISO	June 2026	Open — High Priority	1	3	3	● LOW
WPH-R12	Unauthorized visitor gains physical access to server room due to lack of access controls	Physical Security	Server Room / Infrastructure	2	4	8	● MEDIUM	Protect	Server room has a basic door lock. No key card system. Visitors can access the area with staff.	REDUCE — Install key card access system on server room. Implement visitor log. Install security camera covering server room entrance.	Facilities Manager / IT Manager	August 2026	Open	1	3	3	● LOW
WPH-R13	Weak or default passwords on administrative and privileged IT accounts across hospital systems	Access Control	IT Systems / Network	3	4	12	● HIGH	Protect	Password policy exists on paper but complexity requirements are not technically enforced on all systems.	REDUCE — Enforce password complexity technically on all systems. Implement Privileged Access Management (PAM) for admin accounts. Require MFA for all administrative access.	IT Manager	June 2026	Open — In Progress	1	3	3	● LOW
WPH-R14	No monitoring of who accesses patient records — HIPAA audit log requirement not being met	Compliance / Audit	EHR / Patient Data	3	3	9	● MEDIUM	Detect	Epic EHR has audit logging capability enabled but no process for regular review or alerting.	REDUCE — Assign Privacy Officer to conduct quarterly HIPAA audit log review process. Implement automated alerting for unusual access patterns.	Privacy Officer	June 2026	Open	2	2	4	● LOW
WPH-R15	Cloud storage vendor holding backup patient data has no SOC 2 certification or security documentation	Vendor Risk	Cloud Storage / Patient Data	2	3	6	● MEDIUM	Identify / Protect	Vendor selected based on cost only. No security assessment conducted prior to engagement.	REDUCE — Request SOC 2 Type 2 report from vendor. If unavailable, conduct security questionnaire assessment. Include security requirements in vendor contract.	GRC Analyst	July 2026	Open	1	2	2	● LOW